ZETAH scanner

CONFIDENTIAL

SECURITY ASSESSMENT REPORT

Non-Human Identity Security Assessment

Microsoft Entra ID & Azure · service principals, app registrations, managed identities and AI agents



Demo Corp (synthetic)

Tenant ID demo-tenant-0000

SCAN DATE	05 Nov 2026 09:13 UTC
REPORT GENERATED	05 Nov 2026 09:13 UTC
SCOPE	23 non-human identities · 30 findings
SCAN ID	b2e08892-5c19-4512-845a-2418e494f71b
SCANNER	zetah-scanner 0.1.1 (read-only)

7	17	4	2
CRITICAL	HIGH	MEDIUM	LOW

This report contains security-sensitive information about identities, privileges and attack paths.
Distribute on a need-to-know basis only.

Executive summary

Point-in-time assessment of Demo Corp (synthetic) · 05 Nov 2026



Demo Corp (synthetic) scored **8/100 (At risk)**. The assessment inventoried **23** non-human identities (8 app registrations, 8 service principals, 2 managed identities, 5 AI agents) and raised **30** findings.

7 critical findings represent direct paths to tenant or Azure takeover, or a likely persistence mechanism, and should be remediated immediately.

5 identities (22%) have no accountable owner, so nobody reviews their credentials or permissions.

5 AI agents were identified; 4 carry governance or privilege findings.

7	17	4	2
CRITICAL · IMMEDIATELY	HIGH · WITHIN 30 DAYS	MEDIUM · WITHIN 90 DAYS	LOW · NEXT REVIEW CYCLE

Key indicators

23 Non-human identities	**5** Orphaned (no owner)	**4** Identities with tenant / Azure takeover rights	**5** AI agents identified
2 Dormant or unused with valid credentials	**3** Apps with long-lived secrets	**2** Service principals with hidden credentials	**2** AI agents with an exfiltration path

Top risks

- CRITICAL **AI agent can read tenant data and send it out (exfiltration path)** · Finance Copilot Agent (ai agent)
- CRITICAL **AI agent can read tenant data and send it out (exfiltration path)** · id-foundry-research-agent (ai agent)
- CRITICAL **Tenant-takeover Graph permission: AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory** · Identity Automation (service principal)
- CRITICAL **Tenant-takeover Graph permission: Directory.ReadWrite.All** · legacy-hr-sync (service principal)
- CRITICAL **Privileged Entra role: Privileged Role Administrator** · Identity Automation (service principal)
- CRITICAL **Azure Owner on 1 scope(s)** · func-invoice-processor (managed identity)

Strategic recommendations

1. Apply least privilege in Entra ID. Revoke tenant-takeover Graph permissions and privileged directory roles from workloads, and scope data access with resource-specific consent.

2. Govern AI agents like privileged users. Every agent needs an accountable owner, delegated or scoped permissions, no path from data access to external egress, and secretless authentication.

3. Eliminate static secrets. Move workloads to managed identities or workload identity federation, enforce a maximum secret lifetime (180 days or less) with an app management policy, and remove expired or unexplained credentials.

4. Contain the Azure blast radius. Remove Owner and User Access Administrator from workloads and re-scope Contributor to the resource groups each pipeline actually needs.

5. Decommission unused identities. Disable dormant and never-used identities, revoke their credentials, and review non-human sign-in activity at least quarterly.

Entra Agent ID readiness

Where this tenant's AI agents stand before adopting Microsoft Entra Agent ID: which already are agent identities, which still run as ordinary identities, who is accountable for them, and which to bring under governance first.

5	2	3	2 of 5
AI AGENTS FOUND	ON ENTRA AGENT ID	OUTSIDE AGENT ID	WITH AN ACCOUNTABLE PERSON

Bring under governance first

Agents running as ordinary identities with open findings, riskiest first. They carry the permissions and credentials an attacker would use, without the sponsor and lifecycle that Agent ID adds.

#	Agent	Worst	Findings	Rules	Accountable
1	Finance Copilot Agent App registration / service principal	CRITICAL	6	NHI-AGENT-001 NHI-AGENT-002 NHI-AGENT-003 NHI-AGENT-004 NHI-AGENT-005 NHI-PERM-002	**Nobody**
2	id-foundry-research-agent Managed identity	CRITICAL	3	NHI-AGENT-002 NHI-AGENT-003 NHI-PERM-002	**Nobody**
3	Helpdesk Assistant App registration / service principal	HIGH	1	NHI-PERM-002	it-ops@demo-corp.example

Agents already on Entra Agent ID

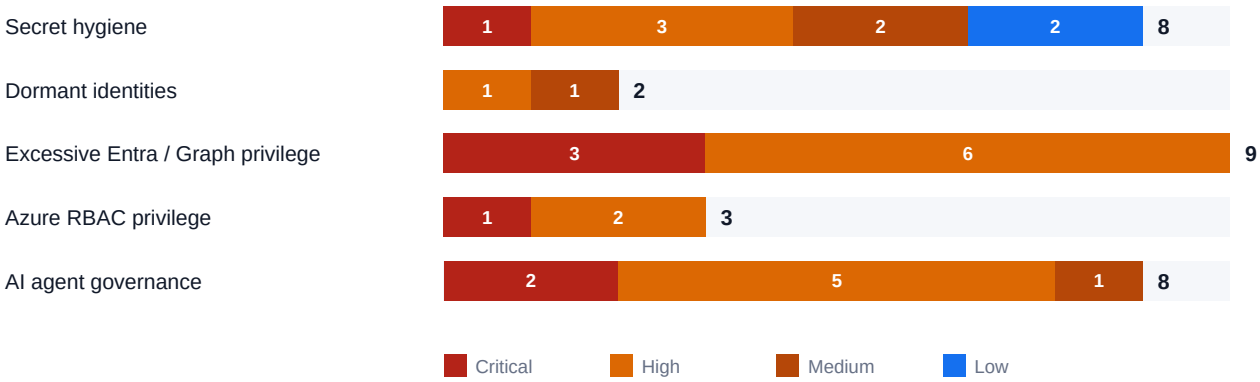
Agent	Owner or sponsor	Worst	Findings
Sales Outreach Agent Agent identity	**No owner or sponsor**	HIGH	1
Procurement Agent Agent identity	procurement-lead@demo-corp.example	-	0

Readiness here means visibility and identity hygiene. It does not assess licensing or how agents are migrated to Agent ID.

Risk overview

Where the exposure sits, by risk category and by identity.

Findings by category and severity



Identity inventory composition

Identity type	Count	With findings	Orphaned	Worst severity
Service principal	8	6	1	CRITICAL
App registration	8	5	2	HIGH
Managed identity	2	1	0	CRITICAL
AI agent	5	4	2	CRITICAL

Most exposed identities

#	Identity	Worst	Findings	Rules	Owner
1	Finance Copilot Agent AI agent	CRITICAL	6	NHI-AGENT-001 NHI-AGENT-002 NHI-AGENT-003 NHI-AGENT-004 NHI-AGENT-005 NHI-PERM-002	**None (orphaned)**
2	id-foundry-research-agent AI agent	CRITICAL	3	NHI-AGENT-002 NHI-AGENT-003 NHI-PERM-002	n/a (by design)
3	Identity Automation Service principal	CRITICAL	2	NHI-PERM-001 NHI-PERM-003	iam-team@demo-corp.example
4	legacy-hr-sync Service principal	CRITICAL	2	NHI-PERM-001 NHI-PERM-003	**None (orphaned)**
5	legacy-hr-sync App registration	HIGH	3	NHI-DORM-001 NHI-SEC-001 NHI-SEC-002	**None (orphaned)**
6	func-invoice-processor Managed identity	CRITICAL	1	NHI-RBAC-001	n/a (by design)
7	ci-deploy-pipeline Service principal	HIGH	2	NHI-RBAC-001 NHI-RBAC-002	devops-lead@demo-corp.example
8	Office 365 Exchange Online Service principal	CRITICAL	1	NHI-SEC-004	n/a (by design)

Remediation plan

Every finding, ordered by priority. P1 items enable tenant or Azure takeover and should be handled immediately; detailed commands are in the next section.

Priority	Issue	Identity	Recommended action
P1 Immediately	01 AI agent can read tenant data and send it out (exfiltration path) NHI-AGENT-003	Finance Copilot Agent AI agent	Remove the egress permission or split read and send capabilities
P1 Immediately	02 AI agent can read tenant data and send it out (exfiltration path) NHI-AGENT-003	id-foundry-research-agent AI agent	Remove the egress permission or split read and send capabilities
P1 Immediately	03 Tenant-takeover Graph permission: AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory NHI-PERM-001	Identity Automation Service principal	Revoke the permission and grant a least-privileged alternative
P1 Immediately	04 Tenant-takeover Graph permission: Directory.ReadWrite.All NHI-PERM-001	legacy-hr-sync Service principal	Revoke the permission and grant a least-privileged alternative
P1 Immediately	05 Privileged Entra role: Privileged Role Administrator NHI-PERM-003	Identity Automation Service principal	Remove the role or replace it with a narrowly scoped one
P1 Immediately	06 Azure Owner on 1 scope(s) NHI-RBAC-001	func-invoice-processor Managed identity	Remove Owner / User Access Administrator; grant narrower roles
P1 Immediately	07 Credentials added to a Microsoft first-party service principal NHI-SEC-004	Office 365 Exchange Online Service principal	Remove the credentials and investigate who added them
P2 Within 30 days	08 Orphaned AI agent: no accountable owner NHI-AGENT-001	Finance Copilot Agent AI agent	Assign an accountable owner or, for Entra Agent ID identities, a sponsor
P2 Within 30 days	09 Orphaned AI agent: no accountable owner NHI-AGENT-001	Sales Outreach Agent AI agent	Assign an accountable owner or, for Entra Agent ID identities, a sponsor
P2 Within 30 days	10 AI agent with tenant-wide write/act permissions (1) NHI-AGENT-002	Finance Copilot Agent AI agent	Replace tenant-wide application permissions with delegated or scoped access
P2 Within 30 days	11 AI agent with tenant-wide write/act permissions (1) NHI-AGENT-002	id-foundry-research-agent AI agent	Replace tenant-wide application permissions with delegated or scoped access
P2 Within 30 days	12 AI agent registered as multi-tenant NHI-AGENT-005	Finance Copilot Agent AI agent	Restrict the sign-in audience to this organization
P2 Within 30 days	13 Dormant for 240 days with 1 valid credential(s) NHI-DORM-001	legacy-hr-sync App registration	Disable the identity, then remove its credentials once nothing breaks
P2 Within 30 days	14 Tenant-wide data access: Files.Read.All, Mail.ReadWrite NHI-PERM-002	Acme Cloud Backup Service principal	Scope access down with resource-specific consent or access policies
P2 Within 30 days	15 Tenant-wide data access: Files.Read.All, Mail.Read, Mail.Send NHI-PERM-002	Finance Copilot Agent AI agent	Scope access down with resource-specific consent or access policies
P2 Within 30 days	16 Tenant-wide data access: Sites.Read.All NHI-PERM-002	Helpdesk Assistant AI agent	Scope access down with resource-specific consent or access policies
P2 Within 30 days	17 Tenant-wide data access: Files.Read.All, Mail.Send NHI-PERM-002	id-foundry-research-agent AI agent	Scope access down with resource-specific consent or access policies

Priority	Issue	Identity	Recommended action
P2 Within 30 days	18 Tenant-wide data access: Sites.FullControl.All NHI-PERM-002	sharepoint-migration-tool Service principal	Scope access down with resource-specific consent or access policies
P2 Within 30 days	19 Privileged Entra role: User Administrator NHI-PERM-003	legacy-hr-sync Service principal	Remove the role or replace it with a narrowly scoped one
P2 Within 30 days	20 Azure User Access Administrator on 1 scope(s) NHI-RBAC-001	ci-deploy-pipeline Service principal	Remove Owner / User Access Administrator; grant narrower roles
P2 Within 30 days	21 Contributor on 1 subscription-level scope(s) NHI-RBAC-002	ci-deploy-pipeline Service principal	Re-scope Contributor to the resource groups actually needed
P2 Within 30 days	22 Client secret valid for 730 days NHI-SEC-002	ci-deploy-pipeline App registration	Replace with workload identity federation, or rotate to secrets of 180 days or less
P2 Within 30 days	23 Client secret valid for 730 days NHI-SEC-002	legacy-hr-sync App registration	Replace with workload identity federation, or rotate to secrets of 180 days or less
P2 Within 30 days	24 Credentials set directly on the service principal NHI-SEC-004	sharepoint-migration-tool Service principal	Remove the credentials and investigate who added them
P3 Within 90 days	25 AI agent authenticates with a static client secret NHI-AGENT-004	Finance Copilot Agent AI agent	Move the agent to a managed identity or federated credentials
P3 Within 90 days	26 Never signed in, yet holds valid credentials NHI-DORM-002	marketing-analytics-poc App registration	Confirm the business purpose; otherwise disable it, then remove its credentials
P3 Within 90 days	27 Client secret valid for 730 days NHI-SEC-002	Finance Copilot Agent App registration	Replace with workload identity federation, or rotate to secrets of 180 days or less
P3 Within 90 days	28 3 active client secrets NHI-SEC-003	Identity Automation App registration	Keep the one secret in use and delete the others
P4 Next review cycle	29 2 expired credential(s) still attached NHI-SEC-001	legacy-hr-sync App registration	Delete expired secrets and certificates
P4 Next review cycle	30 All credentials expire within 11 days NHI-SEC-005	marketing-analytics-poc App registration	Plan the rotation now, preferably to federated credentials

Detailed findings

Technical detail for each finding: what was found, how it can be abused, the evidence collected and the commands to fix it.

Review every command before you run it. These commands change a live tenant and come from a point-in-time scan: check that they still apply, understand what depends on the identity, and run them in a change window. Steps that could break a running workload are commented out on purpose: uncomment them only after the check described above them.

CRITICAL 01 AI agent can read tenant data and send it out (exfiltration path)

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-AGENT-003 · AI agent governance · Priority P1 (immediately) · Finding ID ab127435c1c3e278

FINDING

AI agent 'Finance Copilot Agent' combines broad read access (Files.Read.All, Mail.Read) with an egress channel (Mail.Send): the 'lethal trifecta' of private data, untrusted input and external communication.

Attack path. Indirect prompt injection: an attacker emails or shares a document containing instructions; the agent reads it, collects data via Files.Read.All and exfiltrates it via Mail.Send — no credential theft required.

EVIDENCE

Read permissions: Files.Read.All, Mail.Read
Egress permissions: Mail.Send

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/71d70141-4ea1-5009-add5-597
7bcf6b353/appRoleAssignments/df5b0f44-06e8-5579-816f-ddec1e9596c2 # Mail.Send
```

CRITICAL 02 AI agent can read tenant data and send it out (exfiltration path)

id-foundry-research-agent · AI agent · Object ID 525107c6-ad2d-5652-a103-c39a60ba0e94 · App ID f56b589f-68ee-5695-8ed8-c993c979fc98
Rule NHI-AGENT-003 · AI agent governance · Priority P1 (immediately) · Finding ID 202f58a1b6e49528

FINDING

AI agent 'id-foundry-research-agent' combines broad read access (Files.Read.All) with an egress channel (Mail.Send): the 'lethal trifecta' of private data, untrusted input and external communication.

Attack path. Indirect prompt injection: an attacker emails or shares a document containing instructions; the agent reads it, collects data via Files.Read.All and exfiltrates it via Mail.Send — no credential theft required.

EVIDENCE

Read permissions: Files.Read.All
Egress permissions: Mail.Send

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/525107c6-ad2d-5652-a103-c39
a60ba0e94/appRoleAssignments/e54b8281-20c3-5fe5-85c1-d957fa432cf9 # Mail.Send
```

CRITICAL 03 Tenant-takeover Graph permission: AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory

Identity Automation · Service principal · Object ID 23d10cf8-6099-5143-8db8-f97a738d83cd · App ID 4bda9395-9b53-52ca-8633-32d74601e2f9
Rule NHI-PERM-001 · Excessive Entra / Graph privilege · Priority P1 (immediately) · Finding ID f41a41a8f98a0c7d

FINDING

'Identity Automation' holds Microsoft Graph application permission(s) AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory. Application permissions apply tenant-wide with no user in the loop.

> **Attack path.** Compromise of this identity is equivalent to Global Administrator: AppRoleAssignment.ReadWrite.All can grant itself any Graph permission, including RoleManagement.ReadWrite.Directory; RoleManagement.ReadWrite.Directory can assign itself (or anyone) Global Administrator.

EVIDENCE

Permissions: AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory
Assignments:
- Permission: RoleManagement.ReadWrite.Directory · Assignment id: 67cb6e6d-83e1-5d1c-8281-b813a6576d6e
- Permission: AppRoleAssignment.ReadWrite.All · Assignment id: 6f5f81b5-84d5-51d4-9605-f4aaea6d780e

Orphaned: no

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/23d10cf8-6099-5143-8db8-f97a738d83cd/appRoleAssignments/67cb6e6d-83e1-5d1c-8281-b813a6576d6e # RoleManagement.ReadWrite.Directory
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/23d10cf8-6099-5143-8db8-f97a738d83cd/appRoleAssignments/6f5f81b5-84d5-51d4-9605-f4aaea6d780e # AppRoleAssignment.ReadWrite.All
```

CRITICAL 04 Tenant-takeover Graph permission: Directory.ReadWrite.All

legacy-hr-sync · Service principal · Object ID 59cf3713-48f3-5dce-8d5e-97c546a0e41f · App ID eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45
Rule NHI-PERM-001 · Excessive Entra / Graph privilege · Priority P1 (immediately) · Finding ID 81557c37a1c1d001

FINDING

'legacy-hr-sync' holds Microsoft Graph application permission(s) Directory.ReadWrite.All. Application permissions apply tenant-wide with no user in the loop.

> **Attack path.** Compromise of this identity is equivalent to Global Administrator: Directory.ReadWrite.All can modify users, groups and service principals across the directory. The identity has no owner, so no one is accountable for it.

EVIDENCE

Permissions: Directory.ReadWrite.All
Assignments:
- Permission: Directory.ReadWrite.All · Assignment id: cb724de2-3077-5aae-b66b-63948fd460ac

Orphaned: yes

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/59cf3713-48f3-5dce-8d5e-97c546a0e41f/appRoleAssignments/cb724de2-3077-5aae-b66b-63948fd460ac # Directory.ReadWrite.All
```

CRITICAL 05 Privileged Entra role: Privileged Role Administrator

Identity Automation · Service principal · Object ID 23d10cf8-6099-5143-8db8-f97a738d83cd · App ID 4bda9395-9b53-52ca-8633-32d74601e2f9
Rule NHI-PERM-003 · Excessive Entra / Graph privilege · Priority P1 (immediately) · Finding ID ab096b0dbaeedf2c

FINDING

Service principal 'Identity Automation' is a permanent member of Privileged Role Administrator. Workload identities are excluded from most MFA and Conditional Access controls.

> **Attack path.** Anyone who can authenticate as this identity operates as Privileged Role Administrator and can take over the entire tenant.

EVIDENCE

Roles:

• Role: Privileged Role Administrator · Severity: CRITICAL · Assignment id: 69f52862-af8f-5e2a-81d9-f2b7ba11a9aa · Directory scope: /

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/roleManagement/directory/roleAssignments/69f5
2862-af8f-5e2a-81d9-f2b7ba11a9aa # Privileged Role Administrator
```

CRITICAL 06 Azure Owner on 1 scope(s)

func-invoice-processor · Managed identity · Object ID 3d5ef7e5-9f16-5ca3-90fb-3bbf7ee1739b · App ID 79840d1c-d3f1-5890-be3b-378bf84965ac
Rule NHI-RBAC-001 · Azure RBAC privilege · Priority P1 (immediately) · Finding ID 9ea5f8a2f1d2c1c9

FINDING

'func-invoice-processor' holds role-assignment-capable Azure roles (Owner) at subscription scope.

> **Attack path.** These roles can grant any role to any principal. A compromised workload can make an attacker identity Owner, read Key Vault secrets, run commands on VMs and pivot to every managed identity in scope — lateral movement from one leaked secret to the whole Azure estate.

EVIDENCE

Assignments:

• Role: Owner · Scope: /subscriptions/00000000-0000-4000-8000-0000000000a1 · Level: subscription · Assignment id: /subscriptions/00000000-0000-4000-8000-0000000000a1/providers/Microsoft.Authorization/roleAssignments/c68c5f90-9f24-51b9-8f0d-11a38ff3ebda

REMEDIATION · REVIEW BEFORE RUNNING

```
az role assignment delete --ids /subscriptions/00000000-0000-4000-8000-0000000000a1/providers/Microsoft.Auth
orization/roleAssignments/c68c5f90-9f24-51b9-8f0d-11a38ff3ebda
```

CRITICAL 07 Credentials added to a Microsoft first-party service principal

Office 365 Exchange Online · Service principal · Object ID 3b810ed1-c2f1-57fa-9420-3060d44ce500 · App ID 00000002-0000-0ff1-ce00-000000000000
Rule NHI-SEC-004 · Secret hygiene · Priority P1 (immediately) · Finding ID bc1cd12f1e87e296

FINDING

Service principal 'Office 365 Exchange Online' has 1 credential(s) set on the service principal object itself. These do not appear under 'Certificates & secrets' in the portal and are a well-known persistence technique (Solorigate / Midnight Blizzard).

> **Attack path.** An attacker with Application.ReadWrite.All or Application Administrator can silently add a secret here and authenticate as this identity indefinitely. Whoever holds it inherits every permission granted to the identity.

EVIDENCE

Microsoft first party: yes

Credentials:

• Kind: client secret · Key id: 9f73ea88-83ff-5dac-8a48-4d53e2396408 · Display name: sync · Created: 27 Oct 2026 · Expires on: 25 Oct 2028

REMEDIATION · REVIEW BEFORE RUNNING

```
# Check who added them (Entra audit log: 'Add service principal credentials'), then delete what nobody
recognises:
# az ad sp credential delete --id 3b810ed1-c2f1-57fa-9420-3060d44ce500 --key-id
9f73ea88-83ff-5dac-8a48-4d53e2396408
```

HIGH 08 Orphaned AI agent: no accountable owner

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-AGENT-001 · AI agent governance · Priority P2 (within 30 days) · Finding ID 8f88b67c3fe85845

FINDING

AI agent 'Finance Copilot Agent' has no human owner on its service principal or app registration. No one reviews its permissions, prompts, tools or behaviour.

> **Attack path.** Autonomous agents act on untrusted input (mail, documents, chats). Without an owner, prompt-injection abuse or permission creep goes unnoticed and there is nobody to page during an incident.

EVIDENCE

Classification signals: name:copilot
Permissions: Files.Read.All, Mail.Read, Mail.Send

REMEDIATION · REVIEW BEFORE RUNNING

```
az ad app owner add --id d5aea2f1-96ea-57c8-9073-7420aec22627 --owner-object-id "<OWNER_OBJECT_ID>"
```

HIGH 09 Orphaned AI agent: no accountable owner

Sales Outreach Agent · AI agent · Object ID cd62f8b2-5d2b-5943-8e72-f4d3c83d508c · App ID ad346126-6df4-5b72-83ef-f5dd51d8fcdf
Rule NHI-AGENT-001 · AI agent governance · Priority P2 (within 30 days) · Finding ID 002e84b5b8a78edf

FINDING

AI agent 'Sales Outreach Agent' has no owner or sponsor. No one reviews its permissions, prompts, tools or behaviour.

> **Attack path.** Autonomous agents act on untrusted input (mail, documents, chats). Without an owner, prompt-injection abuse or permission creep goes unnoticed and there is nobody to page during an incident.

EVIDENCE

Classification signals: entra_agent_id
Permissions: User.Read.All

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method POST --url 'https://graph.microsoft.com/v1.0/servicePrincipals/cd62f8b2-5d2b-5943-8e72-f4d3
c83d508c/microsoft.graph.agentIdentity/sponsors/$ref' --body '
{"@odata.id":"https://graph.microsoft.com/v1.0/directoryObjects/<SPONSOR_OBJECT_ID>"}'
```

HIGH 10 AI agent with tenant-wide write/act permissions (1)

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-AGENT-002 · AI agent governance · Priority P2 (within 30 days) · Finding ID 2afd61a99d4db5d9

FINDING

AI agent 'Finance Copilot Agent' can take actions across the tenant via application permissions: Mail.Send. Agents should use delegated, user-scoped access or resource-specific consent.

> **Attack path.** OWASP LLM06 Excessive Agency: a single injected instruction in content the agent processes can make it send mail, overwrite files or change directory objects with its own tenant-wide rights.

EVIDENCE

Action permissions: Mail.Send

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/71d70141-4ea1-5009-add5-597
7bcf6b353/appRoleAssignments/df5b0f44-06e8-5579-816f-ddec1e9596c2 # Mail.Send
```

HIGH 11 AI agent with tenant-wide write/act permissions (1)

id-foundry-research-agent · AI agent · Object ID 525107c6-ad2d-5652-a103-c39a60ba0e94 · App ID f56b589f-68ee-5695-8ed8-c993c979fc98
Rule NHI-AGENT-002 · AI agent governance · Priority P2 (within 30 days) · Finding ID 1c5fa85184a7b0a0

FINDING

AI agent 'id-foundry-research-agent' can take actions across the tenant via application permissions: Mail.Send. Agents should use delegated, user-scoped access or resource-specific consent.

> **Attack path.** OWASP LLM06 Excessive Agency: a single injected instruction in content the agent processes can make it send mail, overwrite files or change directory objects with its own tenant-wide rights.

EVIDENCE

Action permissions: Mail.Send

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/525107c6-ad2d-5652-a103-c39
a60ba0e94/appRoleAssignments/e54b8281-20c3-5fe5-85c1-d957fa432cf9 # Mail.Send
```

HIGH 12 AI agent registered as multi-tenant

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-AGENT-005 · AI agent governance · Priority P2 (within 30 days) · Finding ID b2e5274ff930f12d

FINDING

The app behind AI agent 'Finance Copilot Agent' accepts sign-ins from any Entra tenant (signInAudience=AzureADMultipleOrgs).

> **Attack path.** Its credentials authenticate in every tenant that consented to it; a compromise of this agent is a supply-chain compromise for all of them, and anyone can attempt consent phishing with its name.

EVIDENCE

Sign in audience: AzureADMultipleOrgs

REMEDIATION · REVIEW BEFORE RUNNING

```
az ad app update --id d5aea2f1-96ea-57c8-9073-7420aec22627 --sign-in-audience AzureADMyOrg
```

HIGH 13 Dormant for 240 days with 1 valid credential(s)

legacy-hr-sync · App registration · Object ID f5f8be6e-b8e0-5ce8-8a41-d6790201cc46 · App ID eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45
Rule NHI-DORM-001 · Dormant identities · Priority P2 (within 30 days) · Finding ID 6d748ab76eaf7757

FINDING

'legacy-hr-sync' last authenticated 240 days ago but still holds 1 valid credential(s). Nobody would notice if it started signing in again.

> **Attack path.** Dormant identities with live credentials are prime targets: their activity is not baselined, so an attacker using a leaked secret blends in. Whoever holds it inherits Graph Directory.ReadWrite.All; directory role(s) User Administrator — a direct privilege-escalation path.

EVIDENCE

Last sign in: 10 Mar 2026
Days inactive: 240
Threshold days: 90
Active credentials: 1
Privileged: yes

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Disable the identity. This is reversible: set accountEnabled=true to undo it.
az ad sp update --id 59cf3713-48f3-5dce-8d5e-97c546a0e41f --set accountEnabled=false
```

```
# 2. After an observation period with no impact, remove its credentials:
# az ad app credential delete --id eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45 --key-id
963474b3-2d0d-587c-9259-420036e153b1
```

HIGH 14 Tenant-wide data access: Files.Read.All, Mail.ReadWrite

Acme Cloud Backup · Service principal · Object ID 863a805b-6466-54ff-ba12-48e74763b3ed · App ID 6253058b-e16d-5e9f-b46a-55d9174deaee
Rule NHI-PERM-002 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID c65316621ab526c3

FINDING

'Acme Cloud Backup' can read every OneDrive/SharePoint file; read and modify every mailbox. Consider resource-specific consent or Exchange application access policies to scope it down.

> **Attack path.** A stolen token for this identity gives silent, tenant-wide access to business data: bulk exfiltration of mail/files and impersonation without touching any user account or MFA.

EVIDENCE

Permissions: Files.Read.All, Mail.ReadWrite
Assignments:

- Permission: Mail.ReadWrite · Assignment id: dfc0dbf5-9591-50c4-8469-c2fbc078d51d
- Permission: Files.Read.All · Assignment id: 8a4c1438-4606-54ea-b6d9-2ca124a71664

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/863a805b-6466-54ff-ba12-48e
74763b3ed/appRoleAssignments/dfc0dbf5-9591-50c4-8469-c2fbc078d51d # Mail.ReadWrite
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/863a805b-6466-54ff-ba12-48e
74763b3ed/appRoleAssignments/8a4c1438-4606-54ea-b6d9-2ca124a71664 # Files.Read.All
```

HIGH 15 Tenant-wide data access: Files.Read.All, Mail.Read, Mail.Send

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-PERM-002 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID af4e0ea022bf92ef

FINDING

'Finance Copilot Agent' can read every OneDrive/SharePoint file; read every mailbox in the tenant; send mail as any user (BEC / internal phishing). Consider resource-specific consent or Exchange application access policies to scope it down.

> **Attack path.** A stolen token for this identity gives silent, tenant-wide access to business data: bulk exfiltration of mail/files and impersonation without touching any user account or MFA.

EVIDENCE

Permissions: Files.Read.All, Mail.Read, Mail.Send
Assignments:

- Permission: Mail.Read · Assignment id: 68796eea-007a-5904-b6e4-80ff65a72cfb
- Permission: Files.Read.All · Assignment id: 07ea5d1f-4b4f-5aec-bba1-a46507d39c65
- Permission: Mail.Send · Assignment id: df5b0f44-06e8-5579-816f-ddec1e9596c2

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/71d70141-4ea1-5009-add5-597
7bcf6b353/appRoleAssignments/68796eea-007a-5904-b6e4-80ff65a72cfb # Mail.Read
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/71d70141-4ea1-5009-add5-597
7bcf6b353/appRoleAssignments/07ea5d1f-4b4f-5aec-bba1-a46507d39c65 # Files.Read.All
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/71d70141-4ea1-5009-add5-597
7bcf6b353/appRoleAssignments/df5b0f44-06e8-5579-816f-ddec1e9596c2 # Mail.Send
```

HIGH 16 Tenant-wide data access: Sites.Read.All

Helpdesk Assistant · AI agent · Object ID 34b0ade0-3c17-550a-9299-6d91f5026cbc · App ID b546d1a2-b2bd-5644-b647-b4517d6241dd
Rule NHI-PERM-002 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID 6f062e193c697f94

FINDING

'Helpdesk Assistant' can read every SharePoint site. Consider resource-specific consent or Exchange application access policies to scope it down.

> **Attack path.** A stolen token for this identity gives silent, tenant-wide access to business data: bulk exfiltration of mail/files and impersonation without touching any user account or MFA.

EVIDENCE

Permissions: Sites.Read.All
Assignments:
- Permission: Sites.Read.All · Assignment id: d9db69ed-94e0-5c8c-af1f-f32062e0f4f3

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/34b0ade0-3c17-550a-9299-6d9
1f5026cbc/appRoleAssignments/d9db69ed-94e0-5c8c-af1f-f32062e0f4f3 # Sites.Read.All
```

HIGH 17 Tenant-wide data access: Files.Read.All, Mail.Send

id-foundry-research-agent · AI agent · Object ID 525107c6-ad2d-5652-a103-c39a60ba0e94 · App ID f56b589f-68ee-5695-8ed8-c993c979fc98
Rule NHI-PERM-002 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID 4bcc80fa942c32fb

FINDING

'id-foundry-research-agent' can read every OneDrive/SharePoint file; send mail as any user (BEC / internal phishing). Consider resource-specific consent or Exchange application access policies to scope it down.

> **Attack path.** A stolen token for this identity gives silent, tenant-wide access to business data: bulk exfiltration of mail/files and impersonation without touching any user account or MFA.

EVIDENCE

Permissions: Files.Read.All, Mail.Send
Assignments:
- Permission: Files.Read.All · Assignment id: 09ee396e-51ce-50a9-9a4c-1e25fe35e36b
- Permission: Mail.Send · Assignment id: e54b8281-20c3-5fe5-85c1-d957fa432cf9

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/525107c6-ad2d-5652-a103-c39
a60ba0e94/appRoleAssignments/09ee396e-51ce-50a9-9a4c-1e25fe35e36b # Files.Read.All
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/525107c6-ad2d-5652-a103-c39
a60ba0e94/appRoleAssignments/e54b8281-20c3-5fe5-85c1-d957fa432cf9 # Mail.Send
```

HIGH 18 Tenant-wide data access: Sites.FullControl.All

sharepoint-migration-tool · Service principal · Object ID ae72a780-e581-57fe-a706-734a96348248 · App ID c012c9f8-1c39-59a4-bbe2-66cf10d0f4f0
Rule NHI-PERM-002 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID c6e913f428464d90

FINDING

'sharepoint-migration-tool' can full control of every SharePoint site. Consider resource-specific consent or Exchange application access policies to scope it down.

> **Attack path.** A stolen token for this identity gives silent, tenant-wide access to business data: bulk exfiltration of mail/files and impersonation without touching any user account or MFA.

EVIDENCE

Permissions: Sites.FullControl.All
Assignments:
- Permission: Sites.FullControl.All · Assignment id: 0270b4da-dc73-5891-9b07-7ccebea0f7de

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/servicePrincipals/ae72a780-e581-57fe-a706-734
a96348248/appRoleAssignments/0270b4da-dc73-5891-9b07-7ccebea0f7de # Sites.FullControl.All
```

HIGH 19 Privileged Entra role: User Administrator

legacy-hr-sync · Service principal · Object ID 59cf3713-48f3-5dce-8d5e-97c546a0e41f · App ID eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45
Rule NHI-PERM-003 · Excessive Entra / Graph privilege · Priority P2 (within 30 days) · Finding ID d8e1095451f99716

FINDING

Service principal 'legacy-hr-sync' is a permanent member of User Administrator. Workload identities are excluded from most MFA and Conditional Access controls.

> **Attack path.** Anyone who can authenticate as this identity operates as User Administrator, with control over a sensitive slice of the tenant.

EVIDENCE

Roles:

- Role: User Administrator · Severity: HIGH · Assignment id: 0027792a-587c-5cfe-b27d-b490618108fe · Directory scope: /

REMEDIATION · REVIEW BEFORE RUNNING

```
az rest --method DELETE --url https://graph.microsoft.com/v1.0/roleManagement/directory/roleAssignments/0027
792a-587c-5cfe-b27d-b490618108fe # User Administrator
```

HIGH 20 Azure User Access Administrator on 1 scope(s)

ci-deploy-pipeline · Service principal · Object ID 3f70f801-4ce8-5a1d-99e9-2fb50deefece · App ID 721f86b6-720c-5b98-9376-f38c527dee54
Rule NHI-RBAC-001 · Azure RBAC privilege · Priority P2 (within 30 days) · Finding ID bd5dfbd95baacca8

FINDING

'ci-deploy-pipeline' holds role-assignment-capable Azure roles (User Access Administrator) at resource group scope.

> **Attack path.** These roles can grant any role to any principal. A compromised workload can make an attacker identity Owner, read Key Vault secrets, run commands on VMs and pivot to every managed identity in scope — lateral movement from one leaked secret to the whole Azure estate.

EVIDENCE

Assignments:

- Role: User Access Administrator · Scope: /subscriptions/00000000-0000-4000-8000-0000000000a1/resourceGroups/rg-platform · Level: resource_group · Assignment id: /subscriptions/00000000-0000-4000-8000-0000000000a1/resourceGroups/rg-platform/providers/Microsoft.Authorization/roleAssignments/4e333a9b-cf76-50bd-87c3-69cab9ad868e

REMEDIATION · REVIEW BEFORE RUNNING

```
az role assignment delete --ids /subscriptions/00000000-0000-4000-8000-0000000000a1/resourceGroups/rg-platfo
rm/providers/Microsoft.Authorization/roleAssignments/4e333a9b-cf76-50bd-87c3-69cab9ad868e
```

HIGH 21 Contributor on 1 subscription-level scope(s)

ci-deploy-pipeline · Service principal · Object ID 3f70f801-4ce8-5a1d-99e9-2fb50deefece · App ID 721f86b6-720c-5b98-9376-f38c527dee54
Rule NHI-RBAC-002 · Azure RBAC privilege · Priority P2 (within 30 days) · Finding ID 266b412a17624627

FINDING

'ci-deploy-pipeline' is Contributor at subscription or management-group scope. Pipelines rarely need more than a few resource groups.

> **Attack path.** Contributor can deploy and modify any resource: run code on VMs and Automation accounts, read storage keys, and attach privileged managed identities to attacker-controlled resources.

EVIDENCE

Assignments:

• Role: Contributor · Scope: /subscriptions/00000000-0000-4000-8000-0000000000a1 · Level: subscription · Assignment id: /subscriptions/00000000-0000-4000-8000-0000000000a1/providers/Microsoft.Authorization/roleAssignments/affb713d-bc71-563e-9fe5-db669f591de4

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Grant Contributor only where it is needed (repeat for each resource group):
az role assignment create --assignee 721f86b6-720c-5b98-9376-f38c527dee54 --role Contributor --scope "<RESOURCE_GROUP_SCOPE>"
# 2. Confirm the workload still runs, then remove the broad assignment:
# az role assignment delete --ids /subscriptions/00000000-0000-4000-8000-0000000000a1/providers/Microsoft.Authorization/roleAssignments/affb713d-bc71-563e-9fe5-db669f591de4
```

HIGH 22 Client secret valid for 730 days

ci-deploy-pipeline · App registration · Object ID 6ef73c6b-032f-5fcf-a95d-ad6a50129a5b · App ID 721f86b6-720c-5b98-9376-f38c527dee54
Rule NHI-SEC-002 · Secret hygiene · Priority P2 (within 30 days) · Finding ID c5532c3cbd304257

FINDING

'ci-deploy-pipeline' has 1 active client secret(s) with a lifetime above 365 days (longest: 730 days). Long-lived static secrets end up in config files, CI variables and chat history.

> **Attack path.** A leaked long-lived secret stays valid for months without anyone noticing. Whoever holds it inherits Azure Contributor on subscription, User Access Administrator on resource group — a direct privilege-escalation path.

EVIDENCE

Max lifetime days: 730
Policy max days: 365
Credentials:
• Key id: d12787a1-899f-5adf-abe1-7d48511537f4 · Display name: github-actions · Lifetime days: 730 · Expires on: 01 Oct 2027

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Add a federated credential for the workload. Adapt issuer and subject (GitHub Actions example):
# az ad app federated-credential create --id 721f86b6-720c-5b98-9376-f38c527dee54 --parameters '{"name":"github-main","issuer":"https://token.actions.githubusercontent.com","subject":"repo:<ORG>/<REPO>:ref:refs/heads/main","audiences":["api://AzureADTokenExchange"]}'
# 2. Switch the workload to it and confirm it signs in.
# 3. Only then delete the old secret(s):
# az ad app credential delete --id 721f86b6-720c-5b98-9376-f38c527dee54 --key-id d12787a1-899f-5adf-abe1-7d48511537f4
```

HIGH 23 Client secret valid for 730 days

legacy-hr-sync · App registration · Object ID f5f8be6e-b8e0-5ce8-8a41-d6790201cc46 · App ID eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45
Rule NHI-SEC-002 · Secret hygiene · Priority P2 (within 30 days) · Finding ID 0e5f9a6f558bee11

FINDING

'legacy-hr-sync' has 1 active client secret(s) with a lifetime above 365 days (longest: 730 days). Long-lived static secrets end up in config files, CI variables and chat history.

> **Attack path.** A leaked long-lived secret stays valid for months without anyone noticing. Whoever holds it inherits Graph Directory.ReadWrite.All; directory role(s) User Administrator — a direct privilege-escalation path.

EVIDENCE

Max lifetime days: 730
Policy max days: 365
Credentials:
• Key id: 963474b3-2d0d-587c-9259-420036e153b1 · Display name: hr-2025 · Lifetime days: 730 · Expires on: 09 Jan 2028

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Add a federated credential for the workload. Adapt issuer and subject (GitHub Actions example):
```

```
# az ad app federated-credential create --id eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45 --parameters '
{"name":"github-main","issuer":"https://token.actions.githubusercontent.com","subject":"repo:<ORG>/<REPO>:re
f:refs/heads/main","audiences":["api://AzureADTokenExchange"]}'
# 2. Switch the workload to it and confirm it signs in.
# 3. Only then delete the old secret(s):
# az ad app credential delete --id eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45 --key-id
963474b3-2d0d-587c-9259-420036e153b1
```

HIGH 24 Credentials set directly on the service principal

sharepoint-migration-tool · Service principal · Object ID ae72a780-e581-57fe-a706-734a96348248 · App ID c012c9f8-1c39-59a4-bbe2-66cf10d0f4f0
Rule NHI-SEC-004 · Secret hygiene · Priority P2 (within 30 days) · Finding ID 254b249f26e5ab48

FINDING

Service principal 'sharepoint-migration-tool' has 1 credential(s) set on the service principal object itself. These do not appear under 'Certificates & secrets' in the portal and are a well-known persistence technique (Solorigate / Midnight Blizzard).

> **Attack path.** An attacker with Application.ReadWrite.All or Application Administrator can silently add a secret here and authenticate as this identity indefinitely. Whoever holds it inherits every permission granted to the identity.

EVIDENCE

Microsoft first party: no
Credentials:
- Kind: client secret · Key id: e1b7c172-abef-58b4-abf5-ace4be0381f2 · Display name: added-via-graph · Created: 15 Oct 2026 · Expires on: 14 Oct 2028

REMEDIATION · REVIEW BEFORE RUNNING

```
# Check who added them (Entra audit log: 'Add service principal credentials'), then delete what nobody
recognises:
# az ad sp credential delete --id ae72a780-e581-57fe-a706-734a96348248 --key-id
e1b7c172-abef-58b4-abf5-ace4be0381f2
```

MEDIUM 25 AI agent authenticates with a static client secret

Finance Copilot Agent · AI agent · Object ID 71d70141-4ea1-5009-add5-5977bcf6b353 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-AGENT-004 · AI agent governance · Priority P3 (within 90 days) · Finding ID 75947b44f47e9a1b

FINDING

AI agent 'Finance Copilot Agent' uses 1 client secret(s) instead of a managed identity or workload identity federation.

> **Attack path.** Agent runtimes expose their environment to tools and code interpreters; a secret in an env var or config file can be read back through the agent itself and replayed from anywhere.

EVIDENCE

Client secrets:
- Key id: 5436ed7a-ccad-568e-a6d4-7125229b20e6 · Expires on: 18 Apr 2028

REMEDIATION · REVIEW BEFORE RUNNING

```
# Best option on Azure: host the agent with a managed identity. Otherwise:
# 1. Add a federated credential for the workload. Adapt issuer and subject (GitHub Actions example):
# az ad app federated-credential create --id d5aea2f1-96ea-57c8-9073-7420aec22627 --parameters '
{"name":"github-main","issuer":"https://token.actions.githubusercontent.com","subject":"repo:<ORG>/<REPO>:re
f:refs/heads/main","audiences":["api://AzureADTokenExchange"]}'
# 2. Switch the workload to it and confirm it signs in.
# 3. Only then delete the old secret(s):
# az ad app credential delete --id d5aea2f1-96ea-57c8-9073-7420aec22627 --key-id
5436ed7a-ccad-568e-a6d4-7125229b20e6
```

MEDIUM 26 Never signed in, yet holds valid credentials

marketing-analytics-poc · App registration · Object ID be15c511-bdab-5ec7-bef1-5241cf63b7cb · App ID f82dda04-e8f5-5cea-91b4-5da750927a8c
Rule NHI-DORM-002 · Dormant identities · Priority P3 (within 90 days) · Finding ID 5c4247a69c54163b

FINDING

'marketing-analytics-poc' has no recorded sign-in in the 300 days since it was created but holds 1 valid credential(s). It is either abandoned or not yet in use.

> **Attack path.** Unused identities with credentials and permissions are free attack surface: first use by an attacker raises no anomaly because there is no history. Whoever holds it inherits every permission granted to the identity.

EVIDENCE

Created: 09 Jan 2026
Age days: 300
Active credentials: 1
Privileged: no

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Disable the identity. This is reversible: set accountEnabled=true to undo it.
az ad sp update --id eaa48941-65f2-5b21-870c-3437fe8dd9c5 --set accountEnabled=false
# 2. After an observation period with no impact, remove its credentials:
# az ad app credential delete --id f82dda04-e8f5-5cea-91b4-5da750927a8c --key-id
bc38e086-30be-53cd-a622-463c5565243f
```

MEDIUM 27 Client secret valid for 730 days

Finance Copilot Agent · App registration · Object ID 9162b6eb-fa78-597f-b69e-f52ec55085c5 · App ID d5aea2f1-96ea-57c8-9073-7420aec22627
Rule NHI-SEC-002 · Secret hygiene · Priority P3 (within 90 days) · Finding ID 8c1499e19aad22c5

FINDING

'Finance Copilot Agent' has 1 active client secret(s) with a lifetime above 365 days (longest: 730 days). Long-lived static secrets end up in config files, CI variables and chat history.

> **Attack path.** A leaked long-lived secret stays valid for months without anyone noticing. Whoever holds it inherits every permission granted to the identity.

EVIDENCE

Max lifetime days: 730
Policy max days: 365
Credentials:
- Key id: 5436ed7a-ccad-568e-a6d4-7125229b20e6 · Display name: prod · Lifetime days: 730 · Expires on: 18 Apr 2028

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Add a federated credential for the workload. Adapt issuer and subject (GitHub Actions example):
# az ad app federated-credential create --id d5aea2f1-96ea-57c8-9073-7420aec22627 --parameters '
{"name":"github-main","issuer":"https://token.actions.githubusercontent.com","subject":"repo:<ORG>/<REPO>:re
f:refs/heads/main","audiences":["api://AzureADTokenExchange"]}'
# 2. Switch the workload to it and confirm it signs in.
# 3. Only then delete the old secret(s):
# az ad app credential delete --id d5aea2f1-96ea-57c8-9073-7420aec22627 --key-id
5436ed7a-ccad-568e-a6d4-7125229b20e6
```

MEDIUM 28 3 active client secrets

Identity Automation · App registration · Object ID 203bdc96-9fa0-5546-b8e9-235e207471fe · App ID 4bda9395-9b53-52ca-8633-32d74601e2f9
Rule NHI-SEC-003 · Secret hygiene · Priority P3 (within 90 days) · Finding ID 0ed91d3a79442553

FINDING

'Identity Automation' has 3 simultaneously valid client secrets. Only one should exist outside a short rotation window; extra secrets are usually forgotten copies.

> **Attack path.** Every additional valid secret is another place the identity can leak from, and an attacker-added secret blends in among legitimate ones. Whoever holds it inherits Graph AppRoleAssignment.ReadWrite.All, RoleManagement.ReadWrite.Directory; directory role(s) Privileged Role Administrator — a direct privilege-escalation path.

EVIDENCE

Active secret count: 3
Key ids: e1ec685a-ba27-5f53-b7ab-6f1bfd1300e3, 77bcbd70-5028-5caf-a97d-a59342edc937, b66b95c9-c0ce-52b6-bb19-7c54b8348583

REMEDIATION · REVIEW BEFORE RUNNING

```
az ad app credential list --id 4bda9395-9b53-52ca-8633-32d74601e2f9 -o table
# Find the secret in use (workload configuration, sign-in logs), then delete only the others:
# az ad app credential delete --id 4bda9395-9b53-52ca-8633-32d74601e2f9 --key-id
e1ec685a-ba27-5f53-b7ab-6f1bfd1300e3
# az ad app credential delete --id 4bda9395-9b53-52ca-8633-32d74601e2f9 --key-id
77bcbd70-5028-5caf-a97d-a59342edc937
# az ad app credential delete --id 4bda9395-9b53-52ca-8633-32d74601e2f9 --key-id
b66b95c9-c0ce-52b6-bb19-7c54b8348583
```

LOW 29 2 expired credential(s) still attached

legacy-hr-sync · App registration · Object ID f5f8be6e-b8e0-5ce8-8a41-d6790201cc46 · App ID eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45
Rule NHI-SEC-001 · Secret hygiene · Priority P4 (next review cycle) · Finding ID fa60657ff82f6e7a

FINDING

App registration 'legacy-hr-sync' still carries 2 expired secret/certificate(s), the oldest expired 412 days ago. They no longer authenticate but signal an unmanaged rotation process.

> **Attack path.** Expired credentials cannot mint tokens, but stale credential slots hide which secrets are actually in use, making a newly planted attacker secret harder to spot during review.

EVIDENCE

Credentials:
- Kind: client secret · Key id: f24e500e-4aa7-5b25-9393-f9707246da17 · Display name: hr-2022 · Expired on: 19 Sep 2025 · Days expired: 412
- Kind: client secret · Key id: bc9cbb91-7eb6-5c93-bdaa-a8c0e3a78805 · Display name: hr-2024 · Expired on: 02 Aug 2026 · Days expired: 95

Max days expired: 412

REMEDIATION · REVIEW BEFORE RUNNING

```
az ad app credential delete --id eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45 --key-id
f24e500e-4aa7-5b25-9393-f9707246da17
az ad app credential delete --id eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45 --key-id
bc9cbb91-7eb6-5c93-bdaa-a8c0e3a78805
```

LOW 30 All credentials expire within 11 days

marketing-analytics-poc · App registration · Object ID be15c511-bdab-5ec7-bef1-5241cf63b7cb · App ID f82dda04-e8f5-5cea-91b4-5da750927a8c
Rule NHI-SEC-005 · Secret hygiene · Priority P4 (next review cycle) · Finding ID 683559f4ce1a883b

FINDING

Every valid credential of 'marketing-analytics-poc' expires within 30 days and no replacement exists yet. Unplanned expiry causes outages and rushed, insecure rotations.

> **Attack path.** Emergency rotations are when secrets get pasted into tickets and chats, or issued with multi-year lifetimes 'to avoid this next time'.

EVIDENCE

Days until expiry: 11
Credentials:
- Key id: bc38e086-30be-53cd-a622-463c5565243f · Expires on: 17 Nov 2026

REMEDIATION · REVIEW BEFORE RUNNING

```
# 1. Add a federated credential for the workload. Adapt issuer and subject (GitHub Actions example):
# az ad app federated-credential create --id f82dda04-e8f5-5cea-91b4-5da750927a8c --parameters '
{"name":"github-main","issuer":"https://token.actions.githubusercontent.com","subject":"repo:<ORG>/<REPO>:re
f:refs/heads/main","audiences":["api://AzureADTokenExchange"]}'
# 2. Switch the workload to it and confirm it signs in.
# or, if a new secret is unavoidable, store it in Key Vault so it never reaches the terminal:
# az keyvault secret set --vault-name "<VAULT_NAME>" --name rotated-f82dda04-e8f5-5cea-91b4-5da750927a8c -o
none --value "$(az ad app credential reset --id f82dda04-e8f5-5cea-91b4-5da750927a8c --append
--display-name rotated --end-date 2027-05-04 --query password -o tsv)"
```

Non-human identity inventory

All 23 identities in scope, as observed at scan time.

Identity	Type	Owner(s)	Last sign-in	Status	Findings
Finance Copilot Agent d5aea2f1-96ea-57c8-9073-7420aec22627	AI agent	**Orphaned**	04 Nov 2026	Enabled	**6 · CRITICAL**
Helpdesk Assistant b546d1a2-b2bd-5644-b647-b4517d6241dd	AI agent	it-ops@demo-corp.example	02 Nov 2026	Enabled	**1 · HIGH**
id-foundry-research-agent f56b589f-68ee-5695-8ed8-c993c979fc98	AI agent	n/a (by design)	04 Nov 2026	Enabled	**3 · CRITICAL**
Procurement Agent 788270a6-4e80-5444-9407-58b223e65e1b	AI agent	procurement-lead@demo-corp.example	Never	Enabled	0
Sales Outreach Agent ad346126-6df4-5b72-83ef-f5dd51d8fcdf	AI agent	**Orphaned**	Never	Enabled	**1 · HIGH**
ci-deploy-pipeline 721f86b6-720c-5b98-9376-f38c527dee54	App registration	devops-lead@demo-corp.example	05 Nov 2026	Enabled	**1 · HIGH**
Finance Copilot Agent d5aea2f1-96ea-57c8-9073-7420aec22627	App registration	**Orphaned**	04 Nov 2026	Enabled	**1 · MEDIUM**
Helpdesk Assistant b546d1a2-b2bd-5644-b647-b4517d6241dd	App registration	it-ops@demo-corp.example	02 Nov 2026	Enabled	0
Identity Automation 4bda9395-9b53-52ca-8633-32d74601e2f9	App registration	iam-team@demo-corp.example	03 Nov 2026	Enabled	**1 · MEDIUM**
legacy-hr-sync eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45	App registration	**Orphaned**	10 Mar 2026	Enabled	**3 · HIGH**
marketing-analytics-poc f82dda04-e8f5-5cea-91b4-5da750927a8c	App registration	growth@demo-corp.example	Never	Enabled	**2 · MEDIUM**
payments-api e70a900c-9e74-58e9-b109-aa2e3b029cf1	App registration	payments-team@demo-corp.example	05 Nov 2026	Enabled	0
sharepoint-migration-tool c012c9f8-1c39-59a4-bbe2-66cf10d0f4f0	App registration	m365-admins@demo-corp.example	01 Nov 2026	Enabled	0
func-invoice-processor 79840d1c-d3f1-5890-be3b-378bf84965ac	Managed identity	n/a (by design)	05 Nov 2026	Enabled	**1 · CRITICAL**
id-aks-workload 5c26141c-d51d-5097-936f-5c868a51b3d5	Managed identity	n/a (by design)	05 Nov 2026	Enabled	0
Acme Cloud Backup 6253058b-e16d-5e9f-b46a-55d9174deaee	Service principal	n/a (by design)	05 Nov 2026	Enabled	**1 · HIGH**
ci-deploy-pipeline 721f86b6-720c-5b98-9376-f38c527dee54	Service principal	devops-lead@demo-corp.example	05 Nov 2026	Enabled	**2 · HIGH**
Identity Automation 4bda9395-9b53-52ca-8633-32d74601e2f9	Service principal	iam-team@demo-corp.example	03 Nov 2026	Enabled	**2 · CRITICAL**
legacy-hr-sync eb1e81d4-3c80-5f0b-bbf5-b20d1eebbd45	Service principal	**Orphaned**	10 Mar 2026	Enabled	**2 · CRITICAL**
marketing-analytics-poc f82dda04-e8f5-5cea-91b4-5da750927a8c	Service principal	growth@demo-corp.example	Never	Enabled	0
Office 365 Exchange Online 00000002-0000-0ff1-ce00-000000000000	Service principal	n/a (by design)	05 Nov 2026	Enabled	**1 · CRITICAL**
payments-api e70a900c-9e74-58e9-b109-aa2e3b029cf1	Service principal	payments-team@demo-corp.example	05 Nov 2026	Enabled	0

Identity	Type	Owner(s)	Last sign-in	Status	Findings
sharepoint-migration-tool c012c9f8-1c39-59a4-bbe2-66cf10d0f4f0	Service principal	m365-admins@demo-corp.example	01 Nov 2026	Enabled	2 · HIGH

Methodology & coverage

How the data was collected, which checks ran and how to read the score.

Approach

zetah-scanner performs a **read-only** collection through Microsoft Graph and Azure Resource Manager. No configuration is changed and no credential values are read: only credential metadata (identifiers, display names, validity dates). Each rule emits at most one finding per identity, aggregating every instance it found into the evidence, so the finding ID stays stable across scans.

Data sources

Source	What it provides	Status
Microsoft Graph · directory	App registrations, service principals, owners, credential metadata	**Collected**
Microsoft Graph · permissions	Application permissions on Microsoft Graph	**Collected**
Microsoft Graph · roles	Entra directory role assignments, directly to service principals	**Collected**
Microsoft Graph · sign-in activity	Last sign-in per service principal (servicePrincipalSignInActivities; requires AuditLog.Read.All and Entra ID P1)	**Collected**
Azure Resource Manager	Role assignments to service principals and managed identities across subscriptions	**Collected**

Checks performed

Rule	Category	Check	Result
NHI-SEC-001	Secret hygiene	Expired credentials still attached	**1 finding**
NHI-SEC-002	Secret hygiene	Long-lived client secrets	**3 findings**
NHI-SEC-003	Secret hygiene	Multiple active client secrets	**1 finding**
NHI-SEC-004	Secret hygiene	Credentials on the service principal object	**2 findings**
NHI-SEC-005	Secret hygiene	All credentials expire soon	**1 finding**
NHI-DORM-001	Dormant identities	Dormant identity with valid credentials	**1 finding**
NHI-DORM-002	Dormant identities	Never-used identity with valid credentials	**1 finding**
NHI-PERM-001	Excessive Entra / Graph privilege	Tenant-takeover Graph permissions	**2 findings**
NHI-PERM-002	Excessive Entra / Graph privilege	Tenant-wide data access	**5 findings**
NHI-PERM-003	Excessive Entra / Graph privilege	Privileged Entra directory role	**2 findings**
NHI-RBAC-001	Azure RBAC privilege	Azure access-control role	**2 findings**
NHI-RBAC-002	Azure RBAC privilege	Broad Azure Contributor	**1 finding**
NHI-AGENT-001	AI agent governance	Orphaned AI agent	**2 findings**
NHI-AGENT-002	AI agent governance	AI agent with excessive agency	**2 findings**
NHI-AGENT-003	AI agent governance	AI agent data-exfiltration path	**2 findings**
NHI-AGENT-004	AI agent governance	AI agent using static secrets	**1 finding**
NHI-AGENT-005	AI agent governance	Multi-tenant AI agent	**1 finding**

Hygiene score

The score starts at 100. Each severity removes points with diminishing returns, up to a cap (critical up to 60, high up to 55, medium up to 15, low up to 5 points), so a tenant with many issues is not simply stuck at zero and fixing them raises the score. The score is a whole number: with many findings of the same severity, several fixes may be needed before it moves by one point, and the finding counts in this report are the exact measure of progress. Any open critical finding caps the score at 74. Bands: 80-100 **Good**, 50-79 **Needs attention**, 0-49 **At risk**.

Severity and priority

Severity	Priority	Meaning
CRITICAL	**P1 · immediately**	Direct path to tenant or Azure takeover, data exfiltration by an AI agent, or a likely persistence mechanism.
HIGH	**P2 · within 30 days**	Tenant-wide data access, privileged roles, or weaknesses on privileged identities.
MEDIUM	**P3 · within 90 days**	Hygiene gaps that enlarge the attack surface or slow incident response.
LOW	**P4 · next review**	Housekeeping and operational risk.

Limitations

- This is a point-in-time assessment; identities and permissions change continuously.
- A clean result covers only the checks listed in this report: it does not prove that an identity is harmless.
- Only application permissions on Microsoft Graph are evaluated. Permissions on other APIs, such as Exchange Online full_access_as_app or SharePoint Online, are not read.
- Entra roles held through role-assignable groups, Azure roles held through groups, and custom Azure roles equivalent to Owner or Contributor are not evaluated.
- AI agents are recognised from Entra Agent ID objects, agent tags and naming patterns. Naming-based classification is heuristic: generic names such as 'agent' or 'bot' count only next to an AI term, so unlabelled agents may be missing. The matched signals are recorded for every agent.
- An app registration and its service principal are separate objects in Entra and are listed as two identities, so identity counts are higher than the number of applications.
- Delegated (user-consented) permissions, Conditional Access for workload identities, federated credentials and activity inside other tenants are out of scope for this version.
- Sign-in activity is recorded per application, not per credential, and only covers sign-ins into this tenant; multi-tenant apps are excluded from dormancy checks for that reason.
- Only the Microsoft global cloud is supported.

Generated by zetah-scanner 0.1.1 on 05 Nov 2026 09:13 UTC · scan b2e08892-5c19-4512-845a-2418e494f71b